hochschule burgenland
University of Applied Sciences

IT-Governance als Einflussfaktor der Verwendung von Multifaktor-Authentifizierung in beruflichen und privaten Kontexten

Bachelorarbeit
Department Informationstechnologie

Von
– Andrea Ungerer –
Andrea Ungerer

Betreuer: Dipl.-Ing. Wolfram Rinke

Department Informationstechnologie –Informationstechnologien–:
–IT-Infrastruktur Management–
Datum: 3. Mai 2026

Inhaltsverzeichnis

1 Kurzfassung und Abstract

1.1 Kurzfassung

Digitale Authentifizierungstechnologien befinden sich in einem strategischen Spannungsfeld zwischen Sicherheit und Usability, welches in der vorliegenden Seminararbeit vorgestellt und diskutiert werden soll. Diese Vielschichtigkeit stellt Unternehmen und Personen vor die Herausforderung, wie sie sensible Daten und Zugriffe darauf nachhaltig sichern können. Ein-Faktor-Authentifizierung kann dieses Problem nicht (mehr) lösen, da dieser Faktor häufig ein singuläres Passwort ist, dessen Anfälligkeit für Manipulation umfangreich dokumentiert wurde (Joseph Bonneau et al., 2015, S. 81-82). Gleichzeitig verzeichnen mehrere europäische Organisationen einen starken Anstieg von identitätsbezogenen Angriffen gegen Einzelpersonen und Unternehmen (European Union Agency for Cybersecurity., 2024, S. 27). Multi-Faktor-Authentifizierung schließt diese Lücke, indem wie im Namen ersichtlich, unterschiedliche zusätzliche Faktoren Teil der Identitätsfeststellung werden (Lawrence O'Gorman und O'Gorman, 2003, S. 2022-2024). Weiters nehmen die Bedrohungen im Internet zu. Angriffsvektoren wie Phishing, Identitätsbetrug und Malware bedrohen Privatpersonen und Unternehmen gleichermaßen. Ein-Faktor-Authentifizierungssysteme stellen in diesem Zusammenhang ein großes Risiko dar, weil sie leicht umgangen werden können, und vor allem in Form von Passworten anfällig sind für menschliche Faktoren, wie Bequemlichkeit oder Vergesslichkeit (Das et al., 2020, S. 5446). Insbesondere sicherheitsrelevante Bereiche wie das Gesundheitswesen, Banken sowie die öffentlichen Verwaltung müssen mit Folgen einer Kompromittierung der Daten rechnen, weshalb Guidelines und Standards dringend notwendig sind (EBA publishes an Opinion on the elements of strong customer authentication under PSD2 | European Banking Authority, o. J., S. 12). Dieser wissenschaftliche Text soll untersuchen, welche Faktoren auf die Verwendung von MFA-Technologien einwirken. Dabei liegt der Fokus teilweise auf dem Bereich Usability und Akzeptanz der Technologie, sondern vorwiegend auf dem Bereich Governance als Einflussfaktor. Dieser wird vor allem in Hinblick auf die wachsende Menge an IT-Regularien und Governance-Anforderungen in unterschiedlichen Kontexten zunehmend auch für Privatpersonen beziehungsweise in privaten Kontexten relevant.

1.2 Abstract

2 Einleitung

2.1 Problemstellung

Digitale Authentifizierungstechnologien bewegen sich in einem strategischen Spannungsfeld zwischen Sicherheit und Usability. Diese Dualität stellt Unternehmen wie Privatpersonen vor die Herausforderung, sensible Daten und Zugriffe nachhaltig zu sichern. Die klassische Ein-Faktor-Authentifizierung (1FA) kann dieses Problem nicht mehr lösen, da der Faktor „Wis-

sen“ (meist ein Passwort) durch menschliche Schwächen wie Vergesslichkeit oder Bequemlichkeit anfällig ist und dessen Manipulierbarkeit in der Literatur umfangreich dokumentiert wurde (Bonneau et al., 2015, S. 81). Gleichzeitig verzeichnen europäische Organisationen einen massiven Anstieg von identitätsbezogenen Angriffen (European Union Agency for Cybersecurity, 2024, S. 27). Angriffsvektoren wie Phishing, Identitätsbetrug und Malware bedrohen dabei private und korporative Akteure gleichermaßen. In diesem Kontext stellt die alleinige Nutzung von Passwörtern ein inakzeptables Risiko dar (Das et al., 2020, S. 5446). Multifaktor-Authentifizierung (MFA) schließt diese Sicherheitslücke, indem sie zusätzliche, voneinander unabhängige Faktoren in die Identitätsfeststellung integriert (O’Gorman, 2003, S. 2023). Insbesondere in sensiblen Sektoren wie dem Gesundheitswesen, dem Bankensektor oder der öffentlichen Verwaltung hätte eine Kompromittierung verheerende Folgen, weshalb verbindliche Standards und Guidelines hier dringend erforderlich sind (EBA, o. J., S. 12). Die vorliegende Arbeit untersucht, welche Faktoren die effektive Nutzung von MFA beeinflussen. Während Aspekte der Usability und Akzeptanz als Rahmenbedingungen betrachtet werden, liegt der primäre Fokus auf IT-Governance als steuerndem Element. Obwohl Governance üblicherweise im Unternehmenskontext verortet wird, gewinnt sie durch die wachsende Anzahl an IT-Regularien (NIS-2, DORA, FIDA, CRA) zunehmend auch für Privatpersonen an Relevanz, da berufliche Sicherheitsvorgaben und private Nutzungsgewohnheiten zunehmend verschwimmen.

2.2 Zielsetzung und wissenschaftliche Fragestellung

Multifaktor-Authentifizierung ist mehr als einfache technische Lösung für die Verwaltung von Identitäten und Zugriffen. Die Technologie muss viele verschiedene Anforderungen erfüllen: Sie soll sicher sein, also effektiv vor Angriffen schützen, und Vorgaben entsprechen, sowie weiters durch einfache Bedienung Fehler vermeiden, die durch schlechte Gewohnheiten oder falsche Anwensung entstehen (Kim et al., 2011, S. 187; Bonneau et al., 2012, S. 94). Beispielsweise muss MFA starke Verschlüsselung haben, um Manipulationen zu widerstehen, und gleichzeitig den Vorschriften von Gesetzen und Standards entsprechen. Außerdem soll sie so einfach zu benutzen sein, dass Nutzer:innen sie verwenden und nicht aus Bequemlichkeit umgehen. In diesem Zusammenhang spielt IT-Governance eine wichtige Rolle. Governance bedeutet hier die Regeln und Pläne, die Unternehmen aufstellen, um Sicherheit mit den Bedürfnissen der Beteiligten in Einklang zu bringen (Wibowo Ramli, 2022, S. 2; IT Governance Institute, 2003, S. 15). Durch diese Richtlinien können Firmen entscheiden, welche Technologien und Prozesse sie verwenden, basierend auf den Authenticator Assurance Levels (AAL), die die Stärke der Authentifizierung messen (NIST, 2017, S. 23). AAL hilft dabei, die richtigen Methoden zu wählen, um Ziele wie Sicherheit und Effizienz zu erreichen. Dadurch passt das Thema gut in den Bereich des strategischen IT-Infrastruktur-Managements, wo langfristige Pläne für die IT gemacht werden (Weill Ross, 2004, S. 8).

Daraus abgeleitet lautet die zentrale Forschungsfrage der vorliegenden Arbeit:

> *Welchen Einfluss hat die IT-Governancen auf die Verwendung von Multifaktor-Authentifizierung in beruflichen und privaten Kontexten?*

Als Unterfragen ergeben sich:

- **Unterfrage 1:** Welche Motivationen zur Umstellung auf MFA gibt es?
- **Unterfrage 2:** Welche Vorgaben kann die IT-Governance auf die Verwendung von MFA im beruflichen Kontext definieren?
- **Unterfrage 3:** Wie konkretisieren sich die technischen und organisatorischen Vorgaben bezogen auf MFA im beruflichen Kontext?
- **Unterfrage 4:** Welche Konsequenzen hat die Umsetzung der IT-Governance-Vorgaben bei der Verwendung der MFA auf die Belegschaft?
- **Unterfrage 5:** Wie wirkt sich die Verwendung der MFA im beruflichen Umfeld auf die private Nutzung aus?

Methodisch stützt sich die vorliegende Arbeit auf ein zweistufiges Forschungsdesign. Den theoretischen Unterbau bildet eine Literaturrecherche, bei der relevante wissenschaftliche Publikationen, Fachartikel und Standards (z. B. NIST, ISO) analysiert werden, um sowohl die technischen Aspekte von MFA als auch die organisatorischen Governance-Faktoren zu beleuchten. Darauf aufbauend erfolgt zur Überprüfung der aufgestellten Hypothesen eine quantitative Datenerhebung in Form einer standardisierten Online-Umfrage. Dieses Vorgehen ermöglicht es, die Nutzungsmuster im beruflichen und privaten Kontext empirisch gegenüberzustellen, den Spill-over-Effekt statistisch zu quantifizieren und weiters Erfolgsfaktoren zu identifizieren. Dafür wurden Personen in Österreich, die regelmäßig in beruflichen und privaten Kontexten mit IT-Systemen und digitalen Authentifizierungsverfahren konfrontiert sind, als Zielgruppe definiert. Die gewonnenen Erkenntnisse tragen dazu bei, die Schnittstelle zwischen beruflicher IT-Governance und privater Sicherheitskultur besser zu verstehen. Die Relevanz dieser Arbeit ergibt sich insbesondere für (angehende) IT-Manager:innen sowie Verantwortliche im Bereich Identity- und Access-Management (IAM), um Entscheidungen mit stärkerem Nutzer:innen-Fokus zu treffen und Organisationen auf die steigenden Anforderungen von regulatorischen Vorgaben vorzubereiten.

3 Grundlagen

3.1 Allgemeine Definitionen

Authentifizierung bezeichnet den technischen Prozess, bei dem ein System die behauptete digitale Identität einer Person prüft. Dabei ist sie strikt von der Identitätsfeststellung (Identity Proofing), also der erstmaligen Überprüfung einer Identität (z. B. durch einen Ausweis), und der Autorisierung zu unterscheiden. Während die Authentifizierung die Frage „Bist ich wirklich die Person, die ich vorgibst zu sein?“ beantwortet, klärt die Autorisierung, welche Rechte dieser Person nach dem Login zustehen.

Klassisch erfolgte die Authentifizierung mittels eines einzelnen Faktors, meist über Wissen in Form eines Passworts. Angesichts der evolutionären Entwicklung von Angriffsformen wie Social Engineering oder automatisierten Passwort-Angriffen empfiehlt der NIST-Rahmen heute risikobasierte Authenticator Assurance Levels (AAL). Diese reichen bis hin zur verpflichtenden Multifaktor-Authentifizierung (MFA), um die Integrität kritischer Infrastrukturen zu gewährleisten. MFA kombiniert mindestens zwei unabhängige Faktorarten, um die Sicherheit exponentiell zu erhöhen:

- **Besitz** („Something you have“): Hierzu zählen physische Gegenstände wie Smartcards, Hardware-Sicherheitsschlüssel (z. B. YubiKeys) oder kryptografische Token.
- **Inhärenz** („Something you are“): Hierunter fallen biometrische Merkmale wie der Fingerabdruck, Irisscan oder die Gesichtserkennung.
- **Wissen** („Something you know“): Das klassische Geheimnis, etwa ein Passwort, eine PIN oder eine Passphrase.

Neue Darstellungen erweitern diese drei klassischen Faktoren um zwei kontextbezogene Dimensionen:

- **Ortsbezug** („Somewhere you are“): Die Verifizierung erfolgt über Geofencing, IP-Adressen-Abgleich oder GPS-Daten.
- **Tätigkeitsbezug** („Something you do“): Verhaltensbiometrie analysiert Muster wie die Tippgeschwindigkeit oder die Dynamik der Mausführung (OWASP, o. J.).

Für den vorliegenden Text liegt der Fokus jedoch auf den drei obengenannten klassischen Faktoren. Einerseits aufgrund ihrer dichteren Forschungslage, andererseits um komplexe Kreuzbeziehungen zu reduzieren, die etwa bei der Analyse von Home-Office-Regelungen und wechselnden IP-Standorten in der Governance entstehen würden.

3.2 Protokolle und Technologien

3.2.1 Authentifizierung & Autorisierung

Die Authentifizierung ist der Prozess, bei dem eine Anspruchstellerin oder ein Anspruchsteller (Claimant) den Besitz und die Kontrolle über Authentifikatoren nachweist. Dieser Nachweis erfolgt gegenüber einem Bestätiger (Verifier).

Da einfache Passwörter anfällig für Diebstahl und Phishing sind, gilt die MFA heute als Standard für erhöhte Sicherheitsanforderungen. Sie erhöht die Barriere für Angreifer, da nicht mehr nur ein einzelnes Geheimnis kompromittiert werden muss, sondern zwei voneinander unabhängige Hürden überwunden werden müssen.

Einmalpasswörter (One-Time Password, OTP) stellen eine häufige Implementierung dar. Sie beruhen auf kurzlebigen Codes, die entweder zeitbasiert (Time-Based One-Time Password, TOTP) oder zählerbasiert (HMAC-based One-Time Password, HOTP) generiert werden.

Wird der Code per App oder Hardware-Token erzeugt, gilt das Verfahren als relativ sicher. Im Gegensatz dazu gelten SMS-basierte Verfahren aufgrund der Anfälligkeit für SIM-Swapping oder das Abfangen im Mobilfunknetz als weniger robust.

Hardware-Token und Smartcards ermöglichen über kryptografische Verfahren wie U2F oder FIDO2 eine sogenannte Challenge-Response-Authentifizierung. Hierbei sendet der Server eine zufällige Herausforderung (Challenge), die vom Token mit einem privaten Schlüssel signiert wird. Diese Lösungen sind besonders resistent gegen Phishing, erfordern jedoch einen höheren organisatorischen Aufwand bei der Hardware-Verwaltung.

Biometrische Verfahren bieten eine hohe Benutzerfreundlichkeit, bringen jedoch Herausforderungen hinsichtlich des Datenschutzes mit sich, da biometrische Daten im Falle eines Diebstahls – im Gegensatz zu Passwörtern – nicht geändert werden können.

3.2.2 Endgeräte

Die Sicherheit des jeweiligen Endgerätes ist für die Autorisierung essenziell, da ein kompromittiertes Gerät, beispielsweise durch Malware, selbst eine starke Authentifizierung wertlos machen kann (**?**, S. 269).

Im Rahmen moderner Authentifizierungsarchitekturen wird daher zwischen zwei Hauptkategorien von Authentifikatoren unterschieden: Plattform-Authentifikatoren und Roaming-Authentifikatoren.

Plattform-Authentifikatoren sind fest in das Endgerät integriert und nutzen hardwarebasierte Sicherheitsmodule wie das Trusted Platform Module (TPM 2.0) oder Apples Secure Enclave. Ein prominentes Beispiel hierfür ist Windows Hello, welches biometrische Merkmale (wie Gesichtserkennung oder Fingerabdruck) mit einer lokalen PIN kombiniert. Die biometrischen Daten verlassen dabei zu keinem Zeitpunkt das Gerät. Stattdessen wird bei erfolgreicher biometrischer Prüfung ein kryptografisches Schlüsselpaar freigegeben, das lokal im TPM gespeichert ist (**?**, S. 80). Dies verhindert sogenannte Phishing-Angriffe, da keine über das Netzwerk übertragbaren Geheimnisse abgefangen werden können. Im Gegensatz dazu stehen Roaming-Authentifikatoren, wie hardwarebasierte USB-Sicherheits-Keys (z.B. YubiKey), die mobil an verschiedenen Geräten eingesetzt werden können (**?**, S. 343).

In modernen Zero-Trust-Architekturen wird keinem Gerät implizit vertraut. Der Sicherheitsstatus des Geräts, die sogenannte Device Posture, wird vor und während des Zugriffs kontinuierlich überwacht. Hierbei fließen verschiedene Parameter wie das aktuelle Patch-Level, der Standort und die Integrität der lokalen Sicherheitssoftware in Echtzeit in die Entscheidungsfindung der Authentifizierung ein (**?**, S. 146).

Zusätzlich helfen Techniken wie das Device Fingerprinting dabei, Geräte anhand von Hard- und Software-Eigenschaften eindeutig zu identifizieren und an spezifische Benutzeraccounts zu binden. Dadurch wird sichergestellt, dass selbst bei bekanntem Passwort kein unbefugter Zugriff von fremden Geräten erfolgen kann, wodurch wirksam Session Hijacking (das Entführen von Sitzungen) verhindert wird (**?**, S. 138).

3.3 MFA und Regulatorik

Die Implementierung von Multifaktor-Authentifizierung (MFA) ist längst nicht mehr nur eine rein technische Entscheidung, sondern wird zunehmend durch europäische und nationale Gesetzgebungsakte mandatiert. Die europäische Gesetzgebung zielt darauf ab, die digitale Resilienz kritischer Infrastrukturen zu erhöhen und ein einheitliches Sicherheitsniveau zu etablieren.

Ein zentraler Treiber dieser Entwicklung ist die überarbeitete Richtlinie über Maßnahmen für ein hohes gemeinsames Cybersicherheitsniveau in der Union (NIS-2-Richtlinie), welche in Österreich durch das neue Netz- und Informationssystemsicherheitsgesetz (NISG 2026) umgesetzt wurde.

Das NISG 2026 verpflichtet betroffene Einrichtungen aus kritischen und wichtigen Sektoren, konkret aber nicht ausschließlich das Finanz- und Gesundheitswesen sowie die öffentliche Verwaltung, zur Implementierung strenger Authentifizierungsmechanismen und dem Ausbau der relevanten IT-Infrastruktur (**?**, Art. 21).

Verschärft wird diese Anforderung für den Finanzsektor durch den *Digital Operational Resilience Act* (DORA), welcher im Januar 2025 in Kraft getreten ist.

DORA verlangt von Finanzunternehmen explizit die Nutzung starker und mehrstufiger Authentifizierungsverfahren, um die Integrität und Vertraulichkeit von Transaktionen und Kundendaten zu schützen (**?**, Art. 28 Abs. 2). Dies erfordert von den Instituten eine kontinuierliche Anpassung ihrer Authentifizierungsinfrastruktur an den aktuellen Stand der Technik.

Ergänzend dazu fordert die Datenschutz-Grundverordnung (DSGVO) in Artikel 32 die Umsetzung geeigneter technischer und organisatorischer Maßnahmen (TOMs), um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Europäische Aufsichtsbehörden, wie der Europäische Datenschutzausschuss (EDSA), interpretieren den Schutz von personenbezogenen Daten mittels MFA mittlerweile als integralen Bestandteil des „Stands der Technik“ (**?**, S. 11). Unternehmen, die auf Authentifizierung mittels einfacher Passwörter setzen, laufen demnach Gefahr, bei Sicherheitsvorfällen ein höheres Bußgeld wegen mangelnder Sorgfaltspflicht zu riskieren (**?**, S. 42).

3.4 Verwendungskontext und Akzeptanz

Im privaten Bereich dominiert oft die Freiwilligkeit, sofern keine Vorgaben wie beispielsweise durch die PSD2 im Banking bestehen.

Hier sind Bequemlichkeit und Usability die Hauptentscheidungskriterien.

Im beruflichen Umfeld hingegen erzwingt die IT-Governance die Nutzung durch Richtlinien. Akzeptanzfaktoren sind hierbei ein intuitives Onboarding, risikobasierte Anpassungen (Authentifizierung nur bei Bedarf) sowie zuverlässige Recovery-Prozesse für den Fall eines Geräteverlusts.

3.5 Usability und Mensch-Maschine-Interaktion

Für das Verständnis der Thematik ist die Mensch-Maschine-Interaktion (HCI) ein Schlüsselkonzept. Im Zentrum steht die Anpassung von Systemen an menschliche Grenzen.

Für das grundlegende Verständnis der Akzeptanz von Authentifizierungsverfahren ist die Mensch-Maschine-Interaktion (HCI) ein zentrales Konzept. In der modernen Sicherheitsforschung hat dabei ein wesentlicher Paradigmenwechsel stattgefunden: Der Mensch wird nicht mehr primär als das „schwächste Glied“ (Weakest Link) und somit als Sicherheitsrisiko betrachtet. Vielmehr wird mangelhaftes und kontraintuitives Systemdesign als eigentliche Ursache für Anwendungsfehler und Umgehungsverhalten identifiziert (**?**, S. 345). Systeme müssen sich folglich an die kognitiven und physischen Grenzen der Nutzenden anpassen, anstatt umgekehrt.

Dieser Ansatzes baut aud dem Konzept der sogeannten Usable Security auf. Dieses fordert, dass Sicherheitsmechanismen so gestaltet sein müssen, dass sie effektiv und gleichzeitig ohne übermäßige kognitive Last bedienbar sind. Die ISO 9241-11 definiert Usability über die drei Dimensionen Effektivität, Effizienz und Zufriedenstellung (**?**, S. 42). Im Kontext der Multi-Faktor-Authentifizierung (MFA) bedeutet dies, dass die Interaktion mit dem Sicherheitsfaktor die eigentliche Arbeitsaufgabe nicht übermäßig dominieren darf.

Ein Einflussfaktor auf die Interaktion ist, dass MFA für Anwender:innen eine Nebenrolle einnimmt. Das primäre Ziel ist der schnelle und unterbrechungsfreie Zugriff auf eine Anwendung oder Ressource.

Wenn das Mental Model (das mentale Model) der Nutzenden nicht mit der zugrunde liegenden Sicherheitsarchitektur übereinstimmt, sinkt die Compliance.

Verstehen Anwender:innen beispielsweise nicht, warum ein zusätzlicher Authentifizierungsschritt notwendig ist, wird dieser als Barriere und nicht als Schutz wahrgenommen (**?**, S. 160).

Ist der Authentifizierungsprozess folglich mit zu vielen Hürden verbunden, führt dies unvermeidlich zu Security Fatigue (Sicherheitsmüdigkeit) oder zur Etablierung riskanter Workarounds wie der Schatten-IT (**?**, S. 1141). Die Gestaltung von MFA-Systemen muss daher die Prinzipien des Design-for-Usability priorisieren. Adaptive und transparente Systeme, die den kognitiven Aufwand minimieren, erhöhen nicht nur die Benutzerzufriedenheit, sondern stärken letztlich auch das Sicherheitsniveau der gesamten Organisation (**?**, S. 201).

3.6 Zwischenfazit der Grundlagen

Zusammenfassend lässt sich festhalten, dass MFA ein hybrides System aus technischer Präzision und menschlicher Interaktion darstellt. Während regulatorische Rahmenbedingungen wie NIS-2 und DORA den organisatorischen Druck zur Implementierung erhöhen, entscheidet die Usability über die tatsächliche Wirksamkeit im Alltag. Die hier definierten Konzepte bilden die Basis für die spätere Analyse des Spill-over-Effekts, bei dem untersucht wird, wie berufliche Routine die privaten Sicherheitsgewohnheiten formt.

4 Stand des Wissens

4.1 Entwicklung und Motivation zur Umstellung auf MFA

Die Entwicklung der digitalen Authentifizierung zeigt den fundamentalen Wandel der globalen Bedrohungslage der letzten Jahrezehnte. Wie O'Gorman (2003, S. 2001) darlegt, hat die Digitalisierung die Identitätsprüfung grundlegend verändert: Sie wandelt sich von einer physischen, auf persönlicher Erkennung basierenden Interaktion hin zu einem anonymen, netzwerkbasierten Prozess (**?**, S. 2001). In der Frühphase der Informationstechnik galt ein statisches Passwort als hinreichender Schutzmechanismus, da der Zugang zu Systemen oft physisch oder auf geschlossene Netzwerke begrenzt war (**?**, S. 80). Die Literatur der letzten Jahre belegt jedoch eine drastische Zunahme von Angriffsvektoren, die genau diesen „Single-Factor"-Ansatz (SFA) systematisch kompromittieren (**?**, S. 78). Identitätsbezogene Angriffe wie Phishing, Identitätsbetrug und Malware-Infektionen bedrohen heute private Nutzer:innen und Organisationen gleichermaßen (**?**, S. 1). Laut aktuellen Bedrohungsanalysen, wie dem ENISA Threat Landscape Report, stellen kompromittierte Zugangsdaten weiterhin einen der primären Infiltrationswege für Ransomware-Angriffe dar (**?**, S. 27). Die Motivation zur Umstellung auf Multi-Faktor-Authentifizierung (MFA) ist daher nicht als kurzlebiger technologischer Trend zu verstehen, sondern als notwendige Reaktion auf die Professionalisierung der Cyberkriminalität (**?**, S. 59). Angreifer nutzen heute automatisierte Verfahren wie Credential Stuffing, um massenhaft gestohlene Passwortlisten bei einer Vielzahl von Diensten gleichzeitig zu testen (**?**, S. 59). Da Nutzer:innen häufig dieselben Passwörter für mehrere Dienste verwenden, führt die Kompromittierung eines einzelnen Dienstes oft zu einer Kettenreaktion in der gesamten digitalen Identität (**?**, S. 4). Moderne Authentifizierungssysteme reagieren auf diese Entwicklung, indem sie zunehmend kontextbezogene Faktoren sowie biometrische Daten integrieren, um die Lücke zwischen maximaler Sicherheit und notwendiger Benutzer:innenfreundlichkeit zu schließen (**?**, S. 14). MFA tritt damit als Baustein moderner Sicherheitsarchitekturen wie (Zero Trust) auf, bei denen kein Zugriff, unabhängig von Einflussfaktoren wie dem Standort, implizit erlaubt wird (**?**, S. 11, 15). Sie geht damit weit über eine reine Zugangskontrolle hinaus und wird zum grundlegenden Baustein der digitalen Resilienz einer Organisation (**?**, S. iii).

4.2 IT-Governance als Rahmenbedingung für MFA

Die Einführung von Multifaktor-Authentifizierung ist kein isoliertes technisches Projekt, sondern eine tiefgreifende strategische Aufgabe der IT-Governance. In diesem Kontext definiert die Governance den organisatorischen Rahmen, der das Sicherheitsbewusstsein (Awareness), verbindliche Audit-Richtlinien und komplexe Compliance-Prozesse systematisch miteinander verknüpft (**?**, S. 6). Organisationen orientieren sich hierbei an international etablierten Frameworks wie der ISO/IEC 27001 oder den NIST Digital Identity Guidelines (**?**, S. 6). Diese Standards dienen als Entscheidungsgrundlage, um für verschiedene Geschäftsprozesse die notwendigen Authenticator Assurance Levels (AAL) festzulegen (**?**, S. 6, 13). Im beruflichen Alltag bedeutet dies eine kontinuierliche Gratwanderung: Governance-Vorgaben

müssen das Sicherheitsniveau durch restriktive Verfahren massiv erhöhen, dürfen dabei jedoch die betriebliche Produktivität und die User Experience (UX) nicht lähmen (**?**, S. 154). Empirische Studien belegen, dass eine Diskrepanz zwischen Governance-Vorgaben und der gelebten Arbeitsrealität gravierende Folgen hat: Zu starre oder als unpraktikabel wahrgenommene Sicherheitsrichtlinien begünstigen die Entstehung von Schatten-IT (**?**, S. 66). Mitarbeitende neigen dazu, unkomfortable Sicherheitshürden durch informelle Workarounds zu umgehen, um ihre primären Arbeitsaufgaben effizient erfüllen zu können (**?**, S. 1, 66). Dies unterstreicht die Notwendigkeit, Governance nicht nur als restriktives Regelwerk, sondern als „Enabler“ (Befähigerin) zu verstehen. Eine effektive Strategie muss daher über die technische Implementierung hinausgehen und flankierende Maßnahmen wie gezielte Schulungsprogramme sowie reibungslose Support-Prozesse adressieren (**?**, S. 2, 4). Insbesondere die Gestaltung der Kontenwiederherstellung (Account Recovery) bei Geräteverlust stellt hierbei eine kritische Governance-Herausforderung dar, da hier Sicherheit und administrativer Aufwand direkt korrelieren (**?**, S. 5446). In der vorliegenden Untersuchung wird dieser Aspekt aufgegriffen, um zu prüfen, inwieweit das Vorhandensein von Schulungen und Support-Strukturen die Akzeptanz von MFA erhöht und das Risiko von Schatten-IT minimiert.

4.3 Technische Konkretisierung und Herausforderungen

Die technische Umsetzung von Multifaktor-Authentifizierung markiert den entscheidenden Übergang von theoretischen Governance-Vorgaben hin zu operativen Sicherheitssystemen. In der aktuellen Forschung gelten FIDO-basierte Verfahren (FIDO2 und WebAuthn) aufgrund ihrer Architektur, die auf asymmetrischer Kryptografie und dem Challenge-Response-Prinzip basiert, als technologischer Goldstandard. Diese Methoden sind inhärent resistent gegen Phishing-Angriffe, da keine geteilten Geheimnisse (wie Passwörter) über das Netzwerk übertragen werden und der private Schlüssel sicher auf einem Authentifikator wie einem YubiKey oder dem Trusted Platform Module (TPM) eines Smartphones verbleibt (**?**, S. 269, 422). Dennoch offenbaren empirische Analysen eine deutliche Diskrepanz zur industriellen Praxis: Ein erheblicher Anteil der eingesetzten Lösungen basiert weiterhin auf klassischen Einmal-Passwörtern (OTP). Diese werden häufig über mobile Applikationen wie den Microsoft Authenticator oder den Google Authenticator mittels zeitbasierter Algorithmen (TOTP) generiert (**?**, S. 5, 13). Der Hauptgrund für diese Persistenz liegt in der kosteneffizienten Skalierbarkeit und der einfacheren Integration in bestehende Altsysteme (Legacy-Infrastrukturen), die moderne Standards oft noch nicht nativ unterstützen (**?**, S. 2–3). Ein kritischer und oft unterschätzter Aspekt der technischen Konkretisierung ist die Gestaltung der Wiederherstellungsprozesse (Account Recovery). Die Forschung belegt, dass selbst technologisch hochsichere MFA-Implementierungen ihre Schutzwirkung verlieren, wenn im Falle eines Token-Verlustes unsichere alternative Identifizierungsmethoden wie einfache Sicherheitsfragen angeboten werden (**?**, S. 3822). Solche „Sollbruchstellen“ werden von Angreifern gezielt für Social Engineering-Attacken genutzt, um die Phishing-Resistenz der Hauptverfahren auszuhebeln (**?**, S. 3822). Um diese Herausforderungen zu adressieren, gewinnen adaptive und risikobasierte Ansätze (RBA) an Bedeutung[cite: 1]. Diese Systeme nutzen maschinelles Lernen, um

das Sicherheitsniveau dynamisch an das aktuelle Risiko anzupassen – beispielsweise durch die Analyse von Standortdaten oder dem Geräte-Status (Device Posture) – ohne die operative Kontinuität durch unnötige Authentifizierungsabfragen zu gefährden (**?**, S. 11, 140, 177). Eine ganzheitliche technische Umsetzung muss daher den gesamten Lebenszyklus der digitalen Identität (Identity Lifecycle) abdecken, von der initialen Registrierung bis hin zu sicheren Recovery-Szenarien (**?**, S. 42).

4.4 Die Nutzungsperspektive: Akzeptanz und Barrieren

Die Effektivität von Multifaktor-Authentifizierung entscheidet sich letztlich nicht an der mathematischen Komplexität der Verschlüsselung, sondern an der Akzeptanz durch die Endanwender:innen (**?**, S. 10). Die Forschung identifiziert die sogenannte Security Fatigue (Sicherheitsmüdigkeit) als ein zentrales psychologisches Hindernis: Wenn MFA-Verfahren im Arbeitsalltag als störende Schikane empfunden werden, sinkt nicht nur die Bereitschaft zur Nutzung, sondern es steigt die Wahrscheinlichkeit für aktives Umgehungsverhalten (**?**, S. 1141). Dabei ist die Wahrnehmung von Sicherheit subjektiv und stark von sozio-demografischen Faktoren sowie dem technischen Vorwissen geprägt (**?**, S. 349). Empirische Studien zeigen hierbei eine interessante Paradoxie auf: Während Laien aus Gründen der Bequemlichkeit häufig biometrische Verfahren (z. B. Gesichtsscan) bevorzugen, äußern IT-Expert:innen vermehrt Vorbehalte hinsichtlich des Datenschutzes (**?**, S. 151). Diese Skepsis gründet vor allem auf der Unwiderruflichkeit biometrischer Daten; im Gegensatz zu einem Passwort kann ein einmal kompromittierter Fingerabdruck nicht neu generiert werden (**?**, S. 151). Eine erfolgreiche MFA-Implementierung muss daher das Design-for-Usability priorisieren, um die kognitive Belastung (Cognitive Load) der Nutzenden zu minimieren (**?**, S. 1, 9). Physische Sicherheitsschlüssel (Hardware-Tokens) bieten zwar ein exzellentes Sicherheitsniveau, stoßen jedoch bei breiten Nutzergruppen oft auf signifikante Adoptionshürden, wenn das initiale Onboarding als zu komplex wahrgenommen wird oder keine ausreichenden Schulungsmaßnahmen zur Verfügung stehen (**?**, S. 6, 46). Darüber hinaus belegen Untersuchungen, dass die Akzeptanz von MFA maßgeblich von der Verfügbarkeit verlässlicher Wiederherstellungsoptionen abhängt (**?**, S. 3140). Die Angst vor dem „Ausgesperrt-Sein“ (Lock-out Anxiety) bei Verlust des Smartphones oder Tokens wirkt als starke Barriere für die freiwillige Aktivierung von MFA-Diensten (**?**, S. 15). In diesem Spannungsfeld fungiert die IT-Governance als regulatorisches Korrektiv, das durch klare Kommunikation und Support-Infrastrukturen die subjektiv wahrgenommene Komplexität senken kann (**?**, S. 4).

4.5 Wirkmechanismen der Nutzung: Spill-over in den privaten Kontext

Die letzte Ebene der Analyse befasst sich mit dem Transfer von Sicherheitskompetenzen und -einstellungen, dem sogenannten Spill-over-Effekt. Die sozialwissenschaftliche und IT-sicherheitsbezogene Literatur belegt, dass berufliche Erfahrungen mit Multifaktor-Authentifizierung (MFA) maßgeblich das private Sicherheitsverhalten prägen können. Der Begriff Spill-over beschreibt dabei das Übertragen von Einstellungen, Verhaltensweisen oder Fähigkeiten von

der Arbeitswelt in den privaten Lebensbereich (**?**, S. 44). Insbesondere bei der Nutzung von Sicherheitstechnologien zeigt sich, dass organisationale Vorgaben nicht isoliert wirken, sondern tiefgreifende Auswirkungen auf die individuelle Wahrnehmung der eigenen IT-Sicherheit haben. Dieser Prozess lässt sich in drei zentrale Mechanismen unterteilen:

- **Kompetenz-Transfer:** Die Angst, sich durch technische Fehler selbst auszusperren Recovery Anxiety), stellt bei der Einführung von MFA eine der größten psychologischen Hürden dar (**?**, S. 15). Durch die kontinuierliche Routine im Berufsalltag bauen Anwender:innen jedoch ein grundlegendes Vertrauen in die Technologie auf. Dieser Kompetenzaufbau führt dazu, dass die anfängliche Scheu vor der Handhabung sinkt und die Technologie zunehmend auch im privaten Umfeld, beispielsweise zur Absicherung von E-Mail-Accounts oder Online-Banking, eingesetzt wird.

- **Awareness-Transfer:** Der berufliche Umgang mit verbindlichen Compliance-Regeln und IT-Sicherheitsrichtlinien schärft das Bewusstsein für den Wert digitaler Identitäten. Nach Wibowo und Ramli (**?**, S. 6) führt die regelmäßige Konfrontation mit MFA am Arbeitsplatz dazu, dass Sicherheitsmaßnahmen nicht mehr als reine Belästigung, sondern als notwendiger Standard angesehen werden. Dieses Bewusstsein wird unbewusst in die private IT-Hygiene integriert, was sich in der vermeintlichen Nutzung von Passwort-Managern und zusätzlichen Schutzmechanismen im Privatleben niederschlägt (**?**, S. 129).

- **Reaktive Ablehnung:** Wird die MFA am Arbeitsplatz jedoch als Mikromanagement oder unverhältnismäßige Form der Überwachung wahrgenommen, kann sich der Effekt umkehren. Nach Das et al. (**?**, S. 15) entsteht in solchen Fällen eine kognitive Abwehrhaltung (Psychological Reactance). Die Betroffenen entwickeln eine negative Assoziation mit der Technologie, was dazu führt, dass sie privat ganz bewusst auf den Einsatz von Sicherheitsmechanismen verzichten, um Autonomie zurückzugewinnen.

Ergänzende Perspektive: Usability und soziokulturelle Einflussfaktoren

Die Nutzung von MFA im Privatbereich ist eng mit der wahrgenommenen Gebrauchstauglichkeit (Usability) verknüpft. Forschung zur Protection Motivation Theory (!!) verdeutlichen, dass Individuen den Schutzbeitrag einer Maßnahme gegen den damit verbundenen kognitiven und zeitlichen Aufwand abwägen (**?**, S. 201). Wenn die berufliche MFA-Lösung als besonders umständlich empfunden wird, sinkt die Wahrscheinlichkeit eines positiven Spillover-Effekts drastisch. Umgekehrt gilt: Bietet die Organisation reibungslose und benutzerfreundliche Verfahren an, dient die berufliche Erfahrung als Bestätigung (Social Proof), dass Sicherheit und Komfort kein Widerspruch sein müssen.

Zusammenfassend lässt sich festhalten, dass MFA im Unternehmen weit über die Bürogrenzen hinaus wirkt. Sie fungiert je nach organisationaler Einbettung entweder als Katalysator für ein sichereres digitales Leben oder als Treiber für eine allgemeine Abneigung gegen Sicherheitstechnologien.

5 Forschungsmethodik

5.1 Forschungsdesign und wissenschaftstheoretische Einordnung

Die vorliegende Arbeit verwendet ein quantitatives Forschungsdesign, das deduktiv ausgerichtet ist. Gemäß diesem Ansatz kann wissenschaftlicher Fortschritt nur durch Falsifikation erzielt werden. Dementsprechend wurden aus der bestehenden Literatur (Usability-Forschung, IT-Governance, Spill-over-Theorie) theoriegeleitete Hypothesen abgeleitet, die empirisch überprüft werden, um die Nullhypothese (H_0) zu verwerfen. Für die Beantwortung der Forschungsfrage – inwiefern IT-Governance als Einflussfaktor auf die private Verwendung von Multifaktor-Authentifizierung (MFA) wirkt – ist ein quantitativer Ansatz zwingend erforderlich. Es gilt, die Stärke und Richtung der Zusammenhänge zwischen der beruflichen MFA-Nutzung, der wahrgenommenen Usability, den Governance-Vorgaben und dem privaten Sicherheitsverhalten zu messen. Während qualitative Methoden tiefere Einblicke in individuelle Motive bieten könnten, erlaubt erst die standardisierte quantitative Erhebung generalisierbare Aussagen über Kausalitäts-Tendenzen und signifikante Korrelationen in der breiten Masse der Erwerbstätigen. Der primäre Fokus der Untersuchung liegt dabei auf der Schnittstelle zwischen Arbeitswelt und Privatleben (Work-Life-Interface bzw. Security Spill-over). Die methodische Bearbeitung dieser Arbeit folgt einem zweistufigen Forschungsdesign, bestehend aus einer systematischen Literaturrecherche und einer darauf aufbauenden, quantitativen Datenerhebung.

5.1.1 Systematische Literaturrecherche als theoretisches Fundament

Den ersten methodischen Schritt bildete eine umfassende Literaturrecherche. Dabei wurden aktuelle wissenschaftliche Publikationen, Fachbeiträge sowie internationale Standards und Regularien (wie beispielsweise die Richtlinien von NIST oder ISO) systematisch analysiert, um die technischen Spezifikationen der Multifaktor-Authentifizierung (MFA) mit etablierten IT-Governance-Faktoren in Verbindung zu setzen. Ziel dieser theoretischen Vorarbeit war es, die Nutzungsmuster im beruflichen und privaten Sektor gegenüberzustellen, kontextuelle Unterschiede herauszuarbeiten sowie zentrale Erfolgsfaktoren und Implementierungshindernisse zu identifizieren. Die Erkenntnisse dieser systematischen Recherche bilden das deduktive Fundament für die Konstruktion des Erhebungsinstruments der anschließenden empirischen Untersuchung.

5.1.2 Operationalisierung und theoriegeleitete Itemgenerierung

Die Konstruktion des Erhebungsinstruments (Fragebogen) stützt sich deduktiv auf die zentralen Erkenntnisse der vorangegangenen Literaturrecherche. Um eine hohe Inhaltsvalidität zu gewährleisten, wurden die in der Literatur identifizierten Hemmnisse und Treiber der MFA-Nutzung in messbare Indikatoren (Items) übersetzt. Die Items wurden dabei primär auf einer fünfstufigen Likert-Skala (1 = „stimme gar nicht zu“ bis 5 = „stimme voll zu“) formuliert.

5.2 Grundgesamtheit und Stichprobenziehung

Um die Validität der Ergebnisse zu gewährleisten, muss die Zielgruppe präzise eingegrenzt werden. Die Grundgesamtheit der vorliegenden Untersuchung bilden **erwerbstätige Personen im DACH-Raum, die im Rahmen ihrer beruflichen Tätigkeit regelmäßig mit IT-Systemen und digitalen Authentifizierungsverfahren konfrontiert sind**. Die Rekrutierung der Proband:innen erfolgt über eine Gelegenheitsstichprobe (Convenience Sampling). Die Distribution des Online-Fragebogens wird primär über berufliche Netzwerke (wie LinkedIn und Xing) sowie private Kommunikationskanäle durchgeführt. Diese Methode ermöglicht eine effiziente und breite Streuung. Im Rahmen der Erhebung wird streng auf die Einhaltung der Datenschutz-Grundverordnung (DSGVO) geachtet. Zu Beginn der Umfrage werden die Teilnehmenden über die Freiwilligkeit, den Zweck der Studie sowie die vollständig anonyme und aggregierte Speicherung der Daten aufgeklärt, was insbesondere bei dem sensiblen Thema IT-Sicherheit unabdingbar ist, um sozial erwünschtes Antwortverhalten zu minimieren. Die Primärdatenerhebung erfolgt mittels einer Online-Umfrage über das Tool *Microsoft Forms*. Diese Methode bietet den Vorteil der Ortsunabhängigkeit, einer leichten Skalierbarkeit sowie einer effizienten digitalen Weiterverarbeitung der Daten. Der verwendete Fragebogen wurde anhand eines klaren dramaturgischen Aufbaus konzipiert: Nach der Einleitung und Klärung des Datenschutzes werden zunächst demografische Daten (Alter, Branche, IT-Affinität) erhoben. Anschließend folgen Fragen zum beruflichen Kontext (Governance-Vorgaben), zum privaten Status Quo der MFA-Nutzung sowie abschließend zur Usability-Bewertung. Die Formulierung der Items orientiert sich an den methodischen Vorgaben der empirischen Sozialforschung, insbesondere den „10 Geboten der Frageformulierung“ nach Porst (2014). Um Verzerrungen zu vermeiden, wird auf Suggestivfragen, doppelte Verneinungen sowie zu komplexe Satzstrukturen verzichtet. Die Erfassung der Einstellungen und Wahrnehmungen erfolgt primär über geschlossene Fragen sowie 5-stufige Likert-Skalen (von „stimme gar nicht zu“ bis „stimme voll zu“).

5.3 Methodisches Vorgehen und Instrumentenentwicklung

5.3.1 Operationalisierung und Itemgenerierung

Zur empirischen Überprüfung der aufgestellten Hypothesen wurden die theoretischen Konstrukte in messbare Fragebogenitems überführt (Operationalisierung). Die Generierung der Items basierte auf den Erkenntnissen der vorangegangenen Literaturrecherche. Um Einstellungen, Wahrnehmungen und Verhaltensweisen der Proband:innen präzise zu erfassen, wurde primär eine fünfstufige Likert-Skala (von 1 = „stimme gar nicht zu“ bis 5 = „stimme voll zu“) gewählt. Dieses Format gewährleistet annähernd gleiche Abstände zwischen den Intervallen und hat sich in der empirischen Einstellungsforschung bewährt (vgl. Rohrmann, 1978). Die Formulierung erfolgte in Frage- und Statementform nach den Richtlinien von Porst (2014), wobei suggestive oder doppelt verneinte Konstruktionen vermieden wurden. Um die theoretischen Konzepte messbar zu machen, wurden die Variablen wie folgt operationalisiert:

- **Abhängige Variable (Private MFA-Nutzung):** Gemessen über die Nutzungshäufigkeit und die Art der privat abgesicherten Dienste (z. B. Social Media, Banking, E-Mail).
- **Unabhängige Variable 1 (IT-Governance):** Gemessen über den wahrgenommenen Druck, die Verbindlichkeit von Richtlinien (Compliance) und die Unterstützung durch den Arbeitgeber (zur Überprüfung von H_1).
- **Unabhängige Variable 2 (Usability):** Gemessen über die wahrgenommene Einfachheit der Bedienung und die kognitive Last, in Anlehnung an etablierte Skalen wie die System Usability Scale (SUS) (zur Überprüfung von H_2).
- **Unabhängige Variable 3 (Spill-over-Effekt):** Erfasst durch Items, die eine psychologische Übertragung von beruflichen Gewohnheiten ins Privatleben abfragen (zur Überprüfung von H_3).

5.3.2 Aufbau des Online-Fragebogens

Der finale Online-Fragebogen (vgl. Anhang) gliedert sich in vier strukturierte Abschnitte, um die definierten Variablen systematisch zu erheben:

1. **Filterfrage und Demografie:** Eine obligatorische Filterfrage stellt sicher, dass die Teilnehmenden zur Grundgesamtheit gehören (berufstätig mit IT-Nutzung). Anschließend werden Kontrollvariablen wie Alter und subjektive IT-Affinität erhoben.
2. **Beruflicher Kontext (IT-Governance):** Erhebung der MFA-Pflicht am Arbeitsplatz, der eingesetzten Methoden sowie Bewertung der Transparenz und Strenge der IT-Sicherheitsrichtlinien.
3. **Privater Kontext und Spill-over-Effekt:** Erfassung des Status Quo der privaten MFA-Nutzung sowie Messung des kompetenzbasierten und psychologischen Übertrags (Spill-over) in das Privatleben.

5.3.3 Pre-Test und Datenerhebung

Vor der eigentlichen Feldphase wurde der Entwurf des Fragebogens einem Pre-Test mit einer kleinen Stichprobe ($n = 5$) unterzogen. Ziel war es, die technische Funktionalität (z. B. korrekte Filterführung, mobile Darstellung), die Bearbeitungsdauer (ca. fünf Minuten) sowie die semantische Verständlichkeit zu prüfen. Basierend auf dem Feedback wurden leichte sprachliche Präzisierungen bei den Fragen zur privaten MFA-Nutzung vorgenommen, um die Validität des Messinstruments zu sichern. Die finale Datenerhebung erfolgte mittels des standardisierten Online-Fragebogens über einen Zeitraum von drei Wochen (KW 13–15 2026), um eine möglichst breite und heterogene Stichprobe zu erreichen. Insgesamt konnten 150 vollständige Datensätze erhoben werden, die in die anschließende statistische Analyse einbezogen werden.

5.4 Datenaufbereitung und Auswertungsverfahren

Die Datenanalyse erfolgt mit der Open-Source-Software *Orange Data Mining*. Die Wahl fiel auf dieses Tool, da es durch seine visuelle Programmierung eine transparente und nachvollziehbare Kombination aus Datenaufbereitung, Datenanalyse und inferenzstatistischer Testung innerhalb einer Workflow-Umgebung ermöglicht. Der gesamte Analyseprozess wurde als Orange-Workflow (`.ows`) dokumentiert. Über das File Widget werden die Rohdaten aus den Befragungen importiert. Im Rahmen der Datenvorverarbeitung werden unvollständige Datensätze ausgeschlossen (*Data Cleaning*). Über die *Feature Selection* und *Edit Domain* werden die Variablentypen definiert (Ordinal für Likert-Skalen, Nominell für demografische Merkmale). Zudem werden Ausreißer (z. B. „Speed-Speeder“ mit unrealistisch kurzen Bearbeitungszeiten) herausgefiltert. Die deskriptive Statistik dient zur Darstellung der Stichprobenverteilung. Mittels des *Distributions Widgets* (Histogramme) werden soziodemografische Daten und allgemeine MFA-Nutzungshäufigkeiten visualisiert. *Box Plots* kommen zum Einsatz, um Unterschiede in der Usability-Bewertung zwischen verschiedenen Nutzergruppen (z. B. hohe vs. niedrige IT-Affinität) visuell zu prüfen.

5.5 Mapping

Block	Variable	Theoretis
A	Gen. Info (Demografie, IT-Affinität) als Selbstberichtete Daten	F
B	IT-Governance und Arbeit	Wibowo und Ramli (20
C	Verwendung	Marky et al. (2022);
D	Spill-over Effekte (Privat)	Colnago et al. (2018); Pra
E	Qualitätssicherung	Offene K

6 Empirische Ergebnisse und Diskussion

Wie im Kapitel Forschungsmethodik beschrieben, wurden die Daten mittels einer Onlineumfrage in Microsoft Forms gesammelt und anschließend analysiert. In diesem Kapitel werden die Ergebnisse der Analyse präsentiert und im Kontext der Forschungsfragen diskutiert.

7 Zusammenfassung

Die vorliegende Arbeit hat gezeigt, dass die technische Sicherheit von Multifaktor-Authentifizierung allein nicht ausreicht, um eine flächendeckende Nutzung zu gewährleisten. Vielmehr hängt ihre Wirksamkeit maßgeblich von der Benutzbarkeit und der Akzeptanz der Anwender:innen ab. Wie die Literaturanalyse verdeutlichte, wird MFA von Nutzer:innen häufig als Störfaktor im Arbeitsfluss oder als zeitraubend wahrgenommen. Insbesondere im privaten Kontext, wo

Nutzer:innen bei technischen Problemen auf sich allein gestellt sind, Risiken nur diffus wahrnehmen, und kein institutioneller Druck besteht, führt diese wahrgenommene Hürde oft zur Umgehung von Sicherheitsmechanismen. In diesem Spannungsfeld tritt IT-Governance als entscheidende Treiberin auf. Im beruflichen Umfeld ersetzt sie die oft fehlende intrinsische Motivation durch regulatorische Notwendigkeit. In der Literaturbetrachtung zeigt sich, dass Governance hier eine Doppelfunktion erfüllt: Einerseits erzwingt sie die Nutzung durch Richtlinien und technische Kontrollen. Andererseits unterstützt sie diesen Zwang durch Support-Strukturen (zum Beispiel Helpdesk, Schulung). Diese senken die Hürden bei der Einrichtung und erleichtern die Fehlerbehebung, und sind im privaten Kontext meistens nicht vorhanden. Ein zentrales Ergebnis dieser Arbeit ist die Beschreibung des sogenannten „Spill-over-Effekts“ als Bindeglied zwischen beruflichen und privaten Kontexten. Die betrachteten Forschungsdokumente legen nahe, dass die verpflichtende Nutzung in beruflichen Kontexten auch die Akzeptanz im privaten Kontext fördern kann. Indem Nutzer:innen im geschützten Unternehmensumfeld Kompetenzen aufbauen und die Verwendung von Technologie normalisieren, sinkt die Hemmschwelle, diese auch privat einzusetzen. Die zentrale Forschungsfrage, wie IT-Governance die Verwendung von MFA beeinflusst, lässt sich somit beantworten: IT-Governance wirkt als Katalysator sowohl durch Supportmaßnahme wie zur Sensibilisierung. Indem Governance im Beruf technische Standards durchsetzt und dafür sensibilisiert, wirkt sie auch in anderen Kontexten, also über Unternehmensgrenzen hinaus und leistet indirekt einen Beitrag zur Erhöhung der privaten Sicherheitskompetenz der Mitarbeitenden.

8 Anhang